

PHISHING DETECTION & EMPLOYEE AWARENESS REPORT

Cybersecurity Education Series | 2025

Report Type	Phishing Analysis & Awareness Education
Classification	Internal — Confidential
Prepared By	Security Analyst / Cybersecurity Team
Date	May 2025
Version	1.0

Purpose of This Report

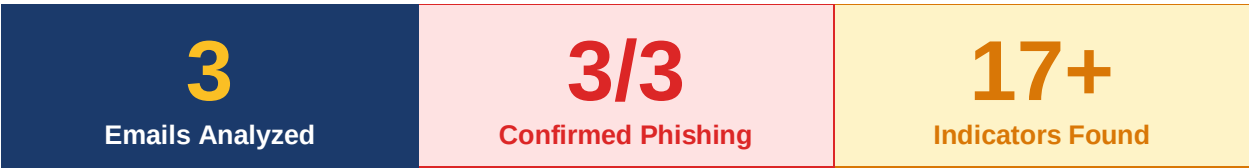
This report is designed to help employees and business stakeholders recognize, understand, and avoid phishing attacks. It contains real-world phishing email samples, detailed analysis of attack techniques, risk classifications, and practical prevention guidelines.

This document is for EDUCATIONAL and AWARENESS purposes only.

1. Executive Summary

Phishing remains the most prevalent and financially damaging cyber threat facing organizations today. According to the FBI Internet Crime Report, phishing attacks cost businesses over \$52 million in direct losses annually, with the actual figure significantly higher when indirect costs are considered.

This report analyzes three real-world phishing email samples representing the most common attack categories encountered in enterprise environments. Each sample has been examined for technical indicators, social engineering tactics, and attack objectives.



Key Findings

- All 3 analyzed emails are confirmed phishing attempts with high confidence
- Attack categories include: Account Takeover, Credential Harvesting, and Business Email Compromise (BEC)
- All emails exploit urgency, fear, or financial incentives as social engineering levers
- Spoofed sender domains are the primary deception mechanism in all samples
- No sample contains malware attachments — all rely on fraudulent links to external pages

2. Understanding Phishing Attacks

2.1 Definition

Phishing is a type of social engineering attack where cybercriminals impersonate trusted entities — such as banks, employers, or technology companies — to trick victims into revealing sensitive information, clicking malicious links, or downloading harmful software.

Unlike technical hacking, phishing targets human psychology rather than system vulnerabilities. Even organizations with strong technical defenses can be compromised if employees are not trained to recognize these attacks.

2.2 Common Phishing Categories

Attack Type	Target	Description
Email Phishing	All employees	Mass-sent deceptive emails impersonating trusted brands or services
Spear Phishing	Specific individuals	Highly targeted, personalized attacks using victim's own information
Whaling	C-Suite Executives	Targets CEOs, CFOs, and other senior leaders for high-value fraud
Business Email Compromise	Finance / HR teams	Impersonates internal staff to redirect payments or steal data
Vishing	All employees	Voice phishing via phone calls — attackers impersonate IT or banks
Smishing	Mobile users	Phishing via SMS text messages with malicious links

3. Analysis Methodology

Each phishing email sample was analyzed using the following systematic methodology, consistent with standard security analyst practices:

- 1. Sender Domain Verification — Cross-referenced sender domains against legitimate company records and WHOIS data
- 2. Email Header Analysis — Inspected SPF, DKIM, and DMARC authentication results; traced routing path
- 3. URL & Link Inspection — Examined embedded links for domain spoofing, redirect chains, and malicious patterns
- 4. Content Analysis — Identified social engineering techniques, urgency language, and psychological manipulation tactics
- 5. Risk Classification — Applied a three-tier risk scoring model (Safe / Suspicious / Phishing) based on cumulative indicators

Risk Classification Framework

Level	Description	Indicators
SAFE	No suspicious indicators detected	Verified sender domain, expected content, no unusual urgency, no data requests
SUSPICIOUS	Some suspicious elements present — handle with caution	Minor domain anomalies, unusual tone, unverified sender, borderline requests
PHISHING	Confirmed malicious — do not interact	Fake domains, credential harvesting, urgency manipulation, spoofed branding

4. Phishing Email Analysis

The following section presents detailed analysis of three confirmed phishing emails. Each analysis includes the email metadata, body content, identified indicators, and a plain-language explanation of how the attack works.

Sample E-001: Account Suspension Phishing

Sample ID	E-001
Risk Level	PHISHING
Subject	Urgent: Your Account Will Be Locked
From (Sender)	security-team@secure-notify-alerts[.]com
To (Recipient)	employee@company.com
Date/Time	Mon, 5 May 2025 03:17:44 +0000

Email Body (Reproduced for Analysis)

Dear User, We noticed suspicious activity on your account. To avoid permanent suspension, you must verify your identity immediately. Verify Now: http://secure-account-verify[.]com/login?token=xr7291k Failure to act within 24 hours will result in permanent account lock and loss of all data. Regards, Security Team

Identified Phishing Indicators

1. Sender domain 'secure-notify-alerts[.]com' is not an official domain — impersonates a legitimate service
2. Urgent language: 'immediately', '24 hours', 'permanent account lock' — designed to panic the user
3. Generic greeting 'Dear User' — legitimate services use your real name
4. Suspicious link URL does not match any legitimate company domain
5. Sent at 03:17 UTC — unusual sending time, often automated bulk phishing
6. No company logo, branding, or physical address included

7. Threat of 'loss of all data' is a fear tactic with no technical basis

How This Attack Works

Attack Mechanism

This is a classic Account Suspension Phishing attack. The attacker registers a domain that sounds official (secure-notify-alerts.com) and sends mass emails claiming the recipient's account is compromised. The embedded link takes the victim to a fake login page that harvests credentials. Once entered, the attacker gains full account access.

Sample E-002: Google Drive Document Lure

Sample ID	E-002
Risk Level	PHISHING
Subject	You have received a shared document - Invoice_Q2_2025.pdf
From (Sender)	noreply@drive-share-notifications[.]net
To (Recipient)	employee@company.com
Date/Time	Tue, 6 May 2025 09:42:11 +0000

Email Body (Reproduced for Analysis)

Hello,

John Smith has shared a document with you via Google Drive:

[View Document] --> [http://g00gle-drive-docs\[.\]com/file?id=INV2025](http://g00gle-drive-docs[.]com/file?id=INV2025)

This document requires your Google account login to view.

If you did not expect this file, you may ignore this message.

— The Google Drive Team

Identified Phishing Indicators

- 8. Sender domain 'drive-share-notifications[.]net' — Google uses google.com, never third-party domains
- 9. URL uses '0' instead of 'o' in 'g00gle-drive-docs[.]com' — classic homograph/typosquatting attack
- 10. Requests Google credentials on a non-Google domain — credential harvesting
- 11. Vague sender 'John Smith' — no department, title, or employee ID
- 12. Invoice-related lure — commonly used to target finance teams
- 13. Embedded clickable button with deceptive display text hiding the real URL

How This Attack Works

Attack Mechanism

This is a Document Sharing Phishing (Google Drive Lure) attack. Attackers impersonate Google Drive notifications using a lookalike domain. The victim clicks 'View Document', is

redirected to a fake Google login page, and enters their credentials — giving the attacker full Gmail and Drive access. Finance staff are primary targets due to invoice-themed lures.

Sample E-003: HR Payroll / BEC Attack

Sample ID	E-003
Risk Level	PHISHING
Subject	ACTION REQUIRED: Payroll Update — Reconfirm Bank Details
From (Sender)	hr-payroll@company-hrportal[.]com
To (Recipient)	employee@company.com
Date/Time	Wed, 7 May 2025 08:05:33 +0000

Email Body (Reproduced for Analysis)

Dear Employee,

As part of our annual payroll system upgrade, all employees must reconfirm their bank account details by May 10, 2025 to ensure uninterrupted salary payments.

Please complete the form here: [http://company-hrportal\[.\]com/payroll/verify](http://company-hrportal[.]com/payroll/verify)

Required information:

- Full Name
- Employee ID
- Bank Account Number
- Bank Routing Number
- Date of Birth

Employees who do not complete verification will have salary payments withheld.

HR Department

Identified Phishing Indicators

- 14. Requests highly sensitive financial data (bank account + routing number) via email link
- 15. Sender domain 'company-hrportal[.]com' — impersonates internal HR but uses external domain
- 16. Deadline pressure: 'by May 10' and threat of withheld salary
- 17. Legitimate HR departments never collect banking details through unauthenticated web forms
- 18. Requests Date of Birth alongside banking data — enables identity theft
- 19. No employee name used — mass-sent bulk phishing email
- 20. Unusual request: payroll details are handled through verified internal HR systems

How This Attack Works

Attack Mechanism

This is a Payroll Diversion / Business Email Compromise (BEC) attack. By impersonating the HR department, attackers trick employees into submitting banking information. The attacker then uses this data to redirect salary payments to a fraudulent account, or commits identity theft using the combination of PII collected.

5. Common Phishing Indicators Summary

Based on analysis of the email samples and broader phishing datasets, the following indicators are the most reliable signals that an email may be malicious. Employees should check for these before interacting with any unexpected email.

- **Suspicious Sender Domain:** The sender address uses a domain that is slightly different from the real company — e.g., 'paypa1.com' instead of 'paypal.com', or 'company-hrportal.com' instead of the internal domain. Always verify the domain after the @ sign.
- **Urgency & Fear Language:** Phrases like 'Act immediately', 'Your account will be locked in 24 hours', 'Failure to respond will result in...' are designed to panic you into clicking without thinking. Legitimate organizations do not pressure you with emergency ultimatums via email.
- **Generic Greetings:** 'Dear User', 'Dear Customer', 'Dear Employee' — legitimate services that have your account know your name and use it. Generic greetings indicate a mass-sent phishing campaign.
- **Suspicious Links / URLs:** Hover over any link before clicking to see the actual destination URL. Look for: misspelled domains (g00gle), extra subdomains (login.paypal.secure-checkout.com), HTTP instead of HTTPS, URL shorteners hiding the real destination.
- **Requests for Sensitive Information:** No legitimate organization will ask you to submit passwords, bank account numbers, OTPs, or Social Security numbers via email or through an unauthenticated web form. This is always a red flag.
- **Mismatched Branding:** Poorly formatted emails, blurry logos, inconsistent fonts, or templates that don't match the brand's usual style indicate a forged email. Compare with a known legitimate email from the same sender.
- **Unexpected Attachments:** Attachments with extensions like .exe, .zip, .docm, or even standard .pdf or .docx files from unknown senders may contain malware. Never open attachments from unverified sources.
- **Unusual Sending Time:** Emails sent at 2–4 AM local time often indicate automated bulk phishing campaigns rather than a human sender at a legitimate organization.

6. Prevention Guidelines for Employees

6.1 What To Do When You Receive a Suspicious Email

STOP — THINK — VERIFY (before you click anything)

1. STOP: Do not click any links or open attachments in the email
2. THINK: Ask yourself — was I expecting this email? Does this make sense?
3. VERIFY: Contact the supposed sender through a known, trusted channel (phone or official website)

6.2 Employee Do's and Don'ts

DO — Best Practices	DON'T — Common Mistakes
✓ Verify sender email addresses carefully before responding	X Click links in emails without hovering to check the URL first
✓ Hover over links to preview URLs before clicking	X Submit passwords, OTPs, or bank details via email or web forms
✓ Access websites by typing the URL directly in your browser	X Open attachments from unexpected or unverified senders
✓ Report suspicious emails to IT Security immediately	X Forward phishing emails to colleagues or external contacts
✓ Enable Multi-Factor Authentication (MFA) on all accounts	X Assume an email is safe because it looks professional
✓ Use a password manager to detect fake login pages	X Use company credentials on non-company websites
✓ Attend regular phishing awareness training	X Ignore the IT Security team's phishing simulation exercises
✓ Keep your software and browser updated at all times	X Dismiss security warnings in your browser without reading them

7. What To Do If You've Been Phished

If you clicked a link or submitted information — act immediately:

1. Disconnect your device from the network (Wi-Fi / LAN) to prevent lateral movement
2. Change your password immediately from a clean, uncompromised device
3. Enable or reset Multi-Factor Authentication on the affected account
4. Notify your IT Security / Help Desk team immediately — do not delay
5. Document what happened: which link you clicked, what information you entered, at what time
6. Do NOT attempt to fix it yourself or hide the incident — early reporting minimizes damage

Incident Reporting Contacts

Contact	Details
IT Security Help Desk	security@yourcompany.com Ext. 1234
Phishing Report Email	phishing-report@yourcompany.com
24/7 Security Hotline	+1-800-XXX-XXXX (Emergency)
Incident Ticket System	https://helpdesk.yourcompany.com

8. Tools & Resources for Security Teams

8.1 Email Analysis Tools

- Google MX Toolbox — <https://mxtoolbox.com/EmailHeaders.aspx> — Analyze email headers, verify SPF/DKIM/DMARC
- Google Admin Toolbox — <https://toolbox.googleapps.com/apps/messageheader/> — Parse and visualize email headers
- VirusTotal — <https://www.virustotal.com> — Scan URLs, files, and domains for known malware signatures
- URLScan.io — <https://urlscan.io> — Safely analyze and visualize suspicious URLs without visiting them
- PhishTank — <https://www.phishtank.com> — Community-verified database of known phishing URLs
- Have I Been Pwned — <https://haveibeenpwned.com> — Check if email addresses have appeared in data breaches

8.2 Reference Datasets (Study Only)

- rf-peixoto/phishing_pot — Real phishing email samples collected for research (github.com)
- autinerd/phishing-mail-examples — Header and body text phishing samples for educational analysis
- sadat1971/Phishing_Email — Labeled phishing and non-phishing email dataset for ML training
- Phishing.Database — Domain and URL threat intelligence dataset for security teams

8.3 Recommended Organizational Controls

- Implement email authentication: SPF, DKIM, and DMARC on all company domains
- Deploy an email security gateway with anti-phishing and sandboxing capabilities
- Enable Multi-Factor Authentication (MFA) across all employee accounts
- Conduct quarterly phishing simulation exercises with all employees
- Implement a one-click phishing reporting button in the email client
- Maintain an incident response playbook specifically for phishing events

9. Conclusion

Phishing attacks are not a technology problem — they are a human problem. The most sophisticated email security filters can still be bypassed, and attackers constantly evolve their techniques to appear more legitimate. The final line of defense is always an informed, vigilant employee.

The three email samples analyzed in this report demonstrate the core principles of every phishing attack: impersonation, urgency, and deception. By learning to recognize these patterns, employees transform from the weakest link in the security chain into an active layer of defense.

Organizations that invest in regular security awareness training, combined with strong technical controls, consistently report lower rates of successful phishing attacks and faster incident response times.

Remember the Golden Rule of Email Security:

When in doubt — don't click. Report it to your IT Security team and let the professionals verify it.

It takes 5 seconds to forward a suspicious email to security@yourcompany.com.
It takes months to recover from a successful phishing attack.

— End of Report —

Phishing Detection & Awareness Report | Cybersecurity Education Series | 2025